# Mecanismos de Segurança e Possíveis Riscos ao Sistema Estudo de Caso

**Guilherme Eduardo Gonçalves da Silva**
**Vinicius Fulber-Garcia**
**João Ribeiro Andreotti**

[1] Universidade Federal do Paraná (UFPR)
Curitiba – PR – Brasil

## 1. Introdução

A *Moving Target Defense* (MTD) é uma estratégia de cibersegurança que altera continuamente os atributos de um sistema ou serviço, utilizando diversidade, embaralhamento e redundância para aumentar a incerteza dos adversários e prevenir ou mitigar ataques [Lei et al. 2018]. Entretanto, apesar de ser uma estratégia promissora, a MTD também apresenta diversos desafios para sua implementação, entre os quais está o chamado Problema de MTD (*MTD Problem*), dividido no Problema da Seleção da Adaptação (*Adaptation Selection Problem*) e no Problema de Temporização (*Timming Problem*) [Zhuang et al. 2014, Zhuang et al. 2015]: o primeiro aborda como um sistema protegido por um mecanismo de MTD deve ser modificado da melhor maneira; o segundo investiga quando essas mudanças devem ocorrer, considerando os compromissos envolvidos na utilização de diferentes gatilhos baseados em tempo ou em eventos. Em particular, o Problema de Temporização tem atraído a atenção da comunidade científica, uma vez que gatilhos mal projetados podem degradar a eficiência do sistema protegido [Zhuang et al. 2012, Wang et al. 2016, Cho et al. 2020].

Embora alguns trabalhos abordem o Problema de Temporização da MTD [Li and Zheng 2019, Tan et al. 2020], argumentamos que o Problema do MTD ainda carece de um terceiro componente para gatilhos baseados em eventos: a legitimidade de acionar uma mudança no sistema, o problema do "por quê" (*Why Problem*). Isso é relevante porque, uma vez que o procedimento de alteração do sistema (o "como") e o vento que aciona (o "quando") estejam definidos e sejam conhecidos, um adversário capaz de influenciar ou falsificar o evento de acionamento obtém controle indireto sobre quando o sistema é reconfigurado, mantendo-o em um estado de mudança contínua e prejudicando sua disponibilidade para usuários legítimos. Essa intenção maliciosa pode manifestar por meio de ataques como falsa sinalização (*false flagging*) [Skopik and Pahi 2020], envenenamento de eventos (*event poisoning)* [Wang et al. 2024], e negação de serviço *(denial-of-service)* [Frasão et al. 2026].

Este caso de tese demonstra brevemente o impacto potencial sobre a disponibilidade do serviço de um mecanismo simples de MTD rotacional com um gatilho baseado em eventos definido de maneira ingênua. Em seguida, apresentamos considerações sobre como levar em conta o problema do "por quê" pode ajudar a impedir que adversários utilizem esses gatilhos como instrumentos de ataques.

## 2. Experimento

Para demonstrar esse efeito, protegemos o cache de uma Rede de Distribuição de Conteúdo (*Content Delivery Network - CDN*) com um mecanismo básico de MTD ro-

tacional, tuilizando três réplicas, cada uma executando uma biblioteca HTTP diferente (Bottle, FastAPI, Flask) em um sistema operacional distinto (Debia, Fedora, Ubuntu). Um gatilho simples baseado em eventos realizava a troca para uma réplica selecionada aleatoriamente a cada 1.000 ou 10.000 pacotes encaminhados. O serviço oferece suporte a dois modos: sem estado (*stateless*), no qual cada réplica possui seu próprio contador de acesso ao conteúdo para priorizar determinado conteúdo; e com estado (*stateful*), no qual as réplicas compartilham o esquema de priorização e a réplica que está sendo desativada transfere os contadores de acesso para que a réplica que está sendo ativada possa se adaptar com base nelas. Cada rotação provoca períodos de indisponibilidade, resultando em falhas nas requisições dos clientes. Com um cliente reailzando requisições em regime de melhor esforço (*best-effort*) durante 300 segundos, a Tabela 1 apresenta as falhas resultantes ao longo de cinco execuções.

**Tabela 1. Request Failures Caused by MTD Rotation**

| Services/Volume | Trigger | Requests | Rotations | Rotations Std. Dev. | Failures | Failures Std. Dev. |
|---|---|---|---|---|---|---|
| 2*Stateless | 1000 p | 183899.8 | 1169.6 | 6.5 | 6.15% | 0.07% |
| | 10000 p | 184008.4 | 177.2 | 3.27 | 0.93% | 0.04% |
| 2*Stateful | 1000 p | 185130.8 | 1140.6 | 5.18 | 9.08% | 0.06% |
| | 10000 p | 180783.6 | 173.4 | 1.52 | 1.41% | 0.03% |

Como mostram os resultados, rotações muito frequentes causam um número não desprezível de falhas nas requisições dos clientes. É importante destacar que essa demonstração não considera nenhum ataque, mas sim o efeito de definir ingenuamente um gatilho baseado em eventos. Entretanto, argumentamos que, uma vez que um adversário mapeie o comportamento do gatilho, ele poderá explorá-lo ativamente. Na demonstração, por exemplo, um adversário poderia enviar tráfego fictício para acionar uma nova rotação assim que a anterior fosse concluída, prejudicando continuamente a disponibilidade do serviço para cliente legítimos.

Isso motiva a incorporação de um componente "por quê" ao Problema da MTD de forma mais ampla: observar, analisar e raciocinar sobre a frequência ou o padrão de ativação de um gatilho. Abordar esse problema é fundamental para impedir que a MTD seja utilizada como instrumento de ataque contra o próprio sistema protegido, garantindo sua segurança e a continuidade do serviço. Contudo, abordar o "por quê" está longe de ser trivial, uma vez que exige compreender a intenção por trás dos eventos que acionam um mecanismo de MTD. Nesse contexto, técnicas como pontuação de anomalias (*anomaly scoring*) [Zohrevand and Glässer 2019], *timeouts* ([Davis et al. 2018]),e discriminação estatística (*[Yu et al. 2013]*) podem ajudar a inferir essa intenção, abrindo oportunidades para prevenir ou mitigar ataques direcionados aos gatilhos.

## 3. Conclusão

A MTD é uma estratégia promissora para proporcionar cibersegurança a sistemas e serviços. Entretanto, se um mecanismo MTD depender de gatilhos baseados em eventos, particularmente aqueles definidos de maneira ingênua, adversários poderão explorar as sobrecargas e os períodos de indisponibilidade resultantes das mudanças no sistema. Ao criar artificialmente condições que acionam continuamente o mecanismo, eles podem interromper o acesso de usuários legítimos. Por tanto, para impedir que adversários utilizem a MTD como instrumento de ataque, é fundamental considerar a motivação real por

trás da frequência e dos padrões de ativação de um gatilho, definindo o que chamamos de Problema do "Por Quê" da MTD (*MTD Why Problem*).

## Referências


Cho, J.-H., Sharma, D. P., et al. (2020). Toward proactive, adaptive defense: A survey on moving target defense. *IEEE Communications Surveys & Tutorials*, 22(1):709–745.

Davis, J. C., Williamson, E. R., and Lee, D. (2018). A sense of time for {JavaScript} and node. js:{First-Class} timeouts as a cure for event handler poisoning. In *USENIX Security Symposium*, pages 343–359.

Frasão, A., Machnicki, R. K., Heinrich, T., and Fulber-Garcia, V. (2026). The "sheep in wolf's clothing" attack: Denial-of-service via reputation poisoning. In *IEEE Symposium on Computers and Communications*, pages 1–6.

Lei, C., Zhang, H.-Q., et al. (2018). Moving target defense techniques: A survey. *Security and Communication Networks*, 2018(1):3759626.

Li, H. and Zheng, Z. (2019). Optimal timing of moving target defense: A stackelberg game model. In *IEEE Military Communications Conference*, pages 1–6.

Skopik, F. and Pahi, T. (2020). Under false flag: using technical artifacts for cyber attack attribution. *Cybersecurity*, 3(1):8.

Tan, J.-l., Zhang, H.-w., Zhang, H.-q., Lei, C., Jin, H., Li, B.-w., and Hu, H. (2020). Optimal timing selection approach to moving target defense: A flipit attack-defense game model. *Security and Communication Networks*, 2020(1):3151495.

Wang, H., Li, F., and Chen, S. (2016). Towards cost-effective moving target defense against ddos and covert channel attacks. In *ACM Workshop on Moving Target Defense*, page 15–25.

Wang, R., Guo, Q., Li, H., and Wan, R. (2024). Event trojan: Asynchronous event-based backdoor attacks. In *European Conference on Computer Vision*, pages 315–332.

Yu, S., Guo, S., and Stojmenovic, I. (2013). Fool me if you can: Mimicking attacks and anti-attacks in cyberspace. *IEEE Transactions on Computers*, 64(1):139–151.

Zhuang, R., Bardas, A. G., DeLoach, S. A., and Ou, X. (2015). A theory of cyber attacks: A step towards analyzing mtd systems. In *ACM Workshop on Moving Target Defense*, pages 11–20.

Zhuang, R., DeLoach, S. A., and Ou, X. (2014). Towards a theory of moving target defense. In *ACM Workshop on Moving Target Defense*, pages 31–40.

Zhuang, R., Zhang, S., et al. (2012). Simulation-based approaches to studying effectiveness of moving-target network defense. In *National Symposium on Moving Target Research*, volume 246, pages 1–12.

Zohrevand, Z. and Glässer, U. (2019). Should i raise the red flag? a comprehensive survey of anomaly scoring methods toward mitigating false alarms. *arXiv Preprint arXiv:1904.06646*.